

Privilege Escalation & Post-Exploitation Techniques

Author: HARSHIL | Date: Aug 13, 2026

1. Executive Summary & Objective

This report details the findings and methodologies applied during Task 5 of the Cybersecurity & Ethical Hacking internship. Following the initial access gained in previous tasks, the primary focus of this phase is to elevate user privileges and maintain persistence within the target system. The objective is to simulate a realistic penetration testing workflow, moving from a standard user shell to administrative or root access, and assessing the potential impact of a compromised environment.

2. Understanding Privilege Escalation

Privilege escalation is a critical phase in the attack lifecycle that occurs after initial access is established. It involves exploiting vulnerabilities, design flaws, or configuration oversights to gain a higher level of access than intended.

- **Vertical Escalation:** This occurs when an attacker grants themselves higher privileges, typically moving from a standard user to a root or administrator account.
- **Horizontal Escalation:** This involves gaining access to another user account with the same level of privileges, often to access different sets of data or move through the network.
- **Criticality:** Escalation is essential because many sensitive files, such as `/etc/shadow`, and powerful commands require root-level permissions to access or execute.

3. Enumeration Findings

Enumeration is the most vital step in the privilege escalation process. It involves gathering detailed information about the target system to identify potential vectors for escalation.

System & User Information

- **System Info:** Identifying the OS version, kernel version, and architecture.
- **User Permissions:** Checking current user IDs, group memberships, and environment variables.
- **Sudo Rights:** Investigating which commands the current user can run with `sudo` without a password.

Enumeration Tools Used

The following tools were utilized to automate and supplement the manual discovery of escalation vectors.

Tool Name	Purpose	Result Reference
LinPEAS	Automated script to identify Linux privilege escalation vectors, kernel exploits, misconfigurations, and stored credentials.	linpeas_output.log (Detailed findings: Kernel 2.6.24-16-server vulnerable to Dirty COW CVE-2016-5195; SUID binary /usr/bin/nmap version 3.50; plaintext MySQL/DVWA credentials in /var/www/dvwa/config/config.inc.php)
LinEnum	Local Linux enumeration script gathering OS details, user accounts, running processes, cron jobs, network connections, and file permissions.	linenum_output.txt (Detailed findings: Kernel x86 2.6.24-16-server; active processes running as root like Apache/MySQL; world-writable /tmp and /var/tmp directories; root cron jobs)
Custom Scripts / Manual Checks	Targeted manual Bash commands to verify SUID/SGID binaries, sudo privileges (sudo -l), sensitive file permissions (/etc/passwd, /etc/shadow), and open network sockets.	Appendix A: Custom Manual Enumeration Logs (Detailed findings: /usr/bin/nmap SUID execution allows GTFOBins interactive shell escape nmap --interactive to spawn root shell; /etc/passwd and /etc/shadow readability and hash structure)

Detailed Tool-by-Tool Findings & Command Outputs

1. LinPEAS (Privilege Escalation Awesome Scripts)

Command Invocation:

```
sh linpeas.sh > linpeas_output.log
```

Key Findings:

- **Kernel Vulnerability:** The system is running kernel version 2.6.24-16-server, which LinPEAS flagged as highly vulnerable to Dirty COW (CVE-2016-5195).
- **SUID Binaries:** Identified /usr/bin/nmap version 3.50 with the SUID bit set, owned by root.
- **Plaintext Credentials:** Discovered sensitive configuration data in /var/www/dvwa/config/config.inc.php containing the database password for the 'root' user.

Analysis:

- **Risk Severity:** Critical
- **Exploitability:** The presence of a 2.6.x kernel makes the system susceptible to well-documented race condition exploits. Furthermore, the plaintext credentials allow for immediate lateral movement or database manipulation.

2. LinEnum

Command Invocation:

```
./LinEnum.sh -t -k keyword -r report.txt
```

Key Findings:

- **Processes:** Confirmed several services (Apache2, MySQL) are executing with root privileges, increasing the attack surface for local service exploitation.
- **Writable Directories:** /tmp and /var/tmp are world-writable, providing a reliable location for staging exploit payloads.
- **Cron Jobs:** Discovered system-wide cron jobs that may be susceptible to file overwrite attacks if the scripts they execute are writable by the current user.

Analysis:

- **Risk Severity:** High
- **Exploitability:** World-writable directories are standard for post-exploitation staging. The root-run processes provide targets for further service-specific enumeration and potential buffer overflow or configuration exploits.

3. Manual Enumeration & Custom Scripts

Command Invocation (SUID Discovery):

```
find / -perm -4000 -type f 2>/dev/null
```

Terminal Log (Abbreviated):

```
Shell
user@metasploitable:~$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/mount
/usr/bin/nmap
/usr/bin/passwd
```

Key Findings:

- **Nmap SUID:** Manual verification of the SUID bit on /usr/bin/nmap.
- **GTFOBins Alignment:** Verified that Nmap version 3.50 supports the --interactive flag, which can be used to escape to a shell.
- **Permissions:** /etc/passwd was checked for write permissions; while not world-writable, /etc/shadow was found to have weak permissions allowing the current user to read password hashes for cracking via John the Ripper.

Analysis:

- **Risk Severity:** Critical

- **Exploitability:** This is the most direct path to root access. By executing `nmap --interactive` and subsequently using the `!sh` command from within the Nmap prompt, the user can spawn a shell that inherits the root privileges of the SUID binary.

Summary of Escalation Path

The enumeration phase successfully identified a "SUID Nmap" vulnerability. This finding directly feeds into the privilege escalation phase:

1. **Discovery:** Nmap 3.50 found with SUID bit via LinPEAS and manual find commands.
2. **Vector:** GTFOBins interactive shell escape.
3. **Execution:** Run `/usr/bin/nmap --interactive`.
4. **Escalation:** Enter `!sh` to gain a root shell.

This path bypasses the need for complex kernel exploits like Dirty COW, providing a more stable and reliable method for gaining full administrative control over the Metasploitable2 instance.

4. Exploiting Misconfigurations

Misconfigured services and improper file permissions are common gateways to root access.

- **SUID Binaries:** These are files that run with the permissions of the file owner (often root) rather than the user executing them. Exploiting these requires tools like GTFOBins to find known bypasses.
- **Writable Files:** Identifying critical system files or configuration files that are incorrectly set to be writable by any user.
- **Misconfigured Services:** Investigating services running as root that may have vulnerabilities or allow for command injection.

5. Password Attacks & Credential Access

If direct exploitation fails, credential access often provides a path forward.

- **Shadow Files:** Accessing `/etc/shadow` is a primary goal, as it contains hashed passwords for all users.
- **Hash Cracking:** Using tools like **John the Ripper** to crack hashes obtained from the system.
- **Brute Force:** Utilizing **Hydra** for service-based brute forcing if weak password policies are identified.

6. Post-Exploitation Activities

Once root access or high-level privileges are achieved, post-exploitation focuses on maximizing the value of the access.

- **Data Extraction:** Identifying and exfiltrating sensitive data, including configuration files, databases, and user documents.
- **Persistence:** Establishing backdoors or scheduled tasks to ensure access remains even after a system reboot.
- **Pivoting:** Using the compromised machine as a jumping-off point to attack other systems on the internal network.

7. Mini Project: Full System Compromise Simulation

Using the **Metasploitable2** lab environment, a full compromise was simulated.

1. **Initial Access:** Gained via `Ⓛ File` (Task 4 Reference).
2. **Enumeration:** Ran LinPEAS and identified an exploitable SUID binary.
3. **Escalation:** Utilized a GTF0Bins technique to spawn a root shell.
4. **Verification:** Confirmed access with the `whoami` and `id` commands.

8. Final Submission Checklist & Summary

The following components have been prepared for final submission as per the project requirements:

- ☐ Detailed enumeration results and logs.
- ☐ Step-by-step exploitation walkthrough.
- ☐ Screenshots of terminal commands and flags.
- ☐ Proof of root privilege escalation (e.g., `id` command output).
- ☐ Final penetration testing report summary.

Summary: This task successfully demonstrated the transition from initial access to full system control. By focusing on enumeration and misconfiguration exploitation, the simulation highlighted the risks of weak permissions and the power of post-exploitation persistence.